

Top 10 web hacking techniques of 2019 - nominations open



James Kettle

Director of Research

[@albinowax](#)



Published: Tuesday, 31 December 2019 at 14:39 UTC

Updated: Monday, 7 September 2020 at 13:49 UTC

Update: the results are now in! View them here: [Top 10 web hacking techniques of 2019](#)

Nominations for the top 10 new web hacking techniques of 2019 are now open!

Every year, professional researchers, seasoned pentesters, bug bounty hunters and academics release a flood of blog posts, presentations, videos and whitepapers. Whether they're suggesting new attack techniques, remixing old ones, or documenting findings, many of these contain novel ideas that can be applied elsewhere.

However, in these days of vulnerabilities arriving equipped with logos and marketing teams it's all too easy for innovative techniques and ideas to get missed in the noise, simply because they weren't broadcast loudly enough. That's why every year, we work with the community to seek out and enshrine ten techniques that we think will withstand the test of time. (We also take offline backups, just in case).

We'll select the top 10 using roughly the same process as last year:

- **Dec 31st:** Start to collect community nominations
- **Jan 13th:** Launch community vote to build a shortlist of the top 15
- **Jan 27th:** Launch panel vote on shortlist to select top 10
- **Feb ~10th:** Publish final top 10

We're planning one significant change from last year. The community nominations have previously been completely unfiltered, but last year that lead to an excessive number of choices for the community vote stage. As such, this year we will enforce a minimum bar for quality - posts that exclusively discuss known techniques and have no novel concepts will be filtered out prior to the community vote. I will also consolidate posts where there's posts on closely related topics - for example, XSLeaks.

To make a nomination, either [use this form](#) or post the URL as a comment on our new [r/websecurityresearch](#) subreddit. Feel free to make multiple nominations, or even nominate your own research if you think it's worthy.

If you'd like to see some examples of the type of material we're looking for, take a look at [last year's top 10](#). We've also made some initial nominations ourselves.

All Nominations:

- [Cached and Confused: Web Cache Deception in the Wild](#)
- [Facebook Messenger server random memory exposure through corrupted GIF](#)
- [Exploring Continuous Integration Services as a Bug Bounty Hunter](#)
- [Cross-Site Leaks](#)
- [HTTP Desync Attacks: Request Smuggling Reborn](#)
- [Let's Make Windows Defender Angry: Antivirus can be an oracle!](#)
- [At Home Among Strangers](#)
- [Exploiting padding oracles with fixed IVs](#)
- [XSS in GMail's AMP4Email via DOM Clobbering](#)
- [Abusing HTTP hop-by-hop request headers](#)
- [Unveiling vulnerabilities in WebSocket APIs](#)
- [CPDoS: Cache Poisoned Denial of Service](#)
- [Security analysis of portal element](#)
- [Owning The Clout Through Server Side Request Forgery](#)
- [Microsoft Edge \(Chromium\) - Elevation of Privilege to Potential RCE](#)
- [Abusing autoresponders and email bounces](#)
- [Infiltrating Corporate Intranet Like NSA: Pre-Auth RCE On Leading SSL VPNs](#)
- [ESI Injection Part 2: Abusing specific implementations](#)
- [A Tale of Exploitation in Spreadsheet File Conversions](#)
- [Reusing Cookies](#)
- [SSRF Protocol Smuggling in Plaintext Credential Handlers : LDAP](#)
- [Exploiting prototype pollution - RCE in Kibana](#)
- [Exploiting SSRF in AWS Elastic Beanstalk](#)
- [Don't open that XML: XXE to RCE in XML plugins for VS Code, Eclipse, Theia, ...](#)
- [Finding and Exploiting .NET Remoting over HTTP using Deserialisation](#)
- [Getting Shell with XAMLX Files](#)
- [Common Security Issues in Financially-Oriented Web Applications](#)
- [IIS Application vs. Folder Detection During Blackbox Testing](#)
- [Exploiting Deserialisation in ASP.NET via ViewState](#)
- [The Cookie Monster in Your Browsers](#)
- [DOMPurify 2.0.0 bypass using mutation XSS](#)
- [XSS-Auditor — the protector of unprotected and the deceiver of protected](#)
- [Get pwned by scanning QR Code](#)
- [Remote Code Execution via Insecure Deserialization in Telerik UI](#)
- [Exploiting Null Byte Buffer Overflow for a \\$40,000 bounty](#)
- [The world of Site Isolation and compromised renderer](#)
- [Hacking Jenkins Part 2 - Abusing Meta Programming for Unauthenticated RCE!](#)
- [All is XSS that comes to the .NET](#)
- [SSO Wars: The Token Menace](#)
- [HostSplit: Exploitable Antipatterns in Unicode Normalization](#)
- [Google Search XSS](#)
- [Backchannel Leaks on Strict Content-Security Policy](#)
- [Uploading web.config for Fun and Profit 2](#)
- [Exploiting Spring Boot Actuators](#)

- [Exploiting JNDI Injections in Java](#)
- [Apache Solr Injection Research](#)
- [PHP-FPM RCE\(CVE-2019-11043\)](#)
- [Bypassing SOP Using the Browser Cache](#)
- [Reverse proxies & Inconsistency](#)
- [x-up-devcap-post-charset Header in ASP.NET to Bypass WAFs Again](#)

PS If you've got experience doing this kind of research yourself, [we're hiring](#).

[top-10-techniques](#)

[← Back to all articles](#)

Related Research



Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering

 **PortSwigger**

[Follow us](#)

© 2026 PortSwigger Ltd.

